

GOOGLE CYBERSECURITY CERTIFICATE

Security Audits — Botium Toys

Google Cybersecurity Professional Certificate · Study Guide

A full NIST CSF-aligned security audit of Botium Toys — asset scope, an 8/10 risk score, a 14-control compliance checklist against PCI DSS/GDPR/SOC, and prioritized hardening recommendations.

Track	Google Cybersecurity Professional Certificate
Course	Assets, Threats, and Vulnerabilities
Framework	NIST CSF — Identify function
Analyst	Chayan Panchal

1 Scope, Goals & Risk Assessment

Scope: the entire security program at Botium Toys, including employee equipment and devices, the internal network, and all systems. Goal: assess existing assets and complete a controls-and-compliance checklist to determine what needs to be implemented to improve the security posture.

Assets managed by IT

On-premises equipment for in-office needs; employee desktops/laptops, phones, remote workstations, cameras

Storefront products for retail sale (on site and online), stored in the adjoining warehouse

Accounting, telecommunication, database, security, ecommerce, and inventory management systems

Internet access and the internal network; data retention and storage; legacy system maintenance

OVERALL RISK Risk score: 8 / 10 (High). Asset management is inadequate, and Botium Toys may not be fully compliant with U.S. and international regulations and standards.

Key findings

Finding	Status
Employee access to cardholder data and PII/SPII	All unrestricted
Encryption of customer credit card data	Not implemented
Least privilege / separation of duties	Not implemented
Intrusion Detection System (IDS)	Not installed
Disaster recovery plans & data backups	None in place
Password policy	Below minimum complexity
Firewall, antivirus, physical security (locks/CCTV/fire)	In place
GDPR 72-hour breach notification plan	In place

2 Controls & Compliance Checklist

Controls assessment

Control	In place?	Notes
Least privilege	No	All employees have access to customer data
Separation of duties	No	CEO runs operations and manages payroll — fraud risk
Disaster recovery / backups	No	Required for business continuity
Encryption	No	Not currently used
Firewall / Antivirus / Physical security	Yes	In place and monitored
IDS	No	Needed to identify intrusions
Legacy system monitoring	Partial	Monitored but no formal schedule

Compliance summary

Standard	Status
PCI DSS	Not compliant — unauthorized access to cardholder data, no encryption, weak password policy
GDPR	Partially compliant — breach notification plan exists, but data isn't encrypted and classification is incomplete
SOC	Not compliant — user access policies and data confidentiality controls are missing

Prioritized recommendations

1. Least privilege — restrict employee data access to role requirements
2. Encryption — implement for all sensitive and cardholder data
3. Separation of duties — split CEO responsibilities from payroll management
4. Disaster recovery plans — develop and test recovery procedures
5. IDS — deploy an intrusion detection system
6. Password policy + centralized management system
7. Asset classification — classify all inventoried assets

3 Hardening Recommendations

Multi-Factor Authentication (MFA)

Requires identity verification in more than one way — fingerprint, ID card, PIN, or password. Reduces the likelihood of a successful brute force attack and discourages password sharing, since a shared password alone becomes insufficient.

Strong password policy

Minimum length and complexity requirements

Account lockout after a defined number of failed attempts (e.g. 5)

Prohibition on reusing previous passwords

Mandatory periodic password updates

Firewall maintenance

Keep firewall rules aligned with current traffic standards

Add suspicious source IPs to a deny list

Update rules after any security event that allowed unexpected traffic

Use firewall configuration as a defense against DoS/DDoS attacks

4 Quick Reference



Security audit — quick reference

NIST CSF: Identify -> Protect -> Detect -> Respond -> Recover

Botium Toys risk score: 8/10 (High)

Top-priority fixes: least privilege, encryption, separation of duties,
disaster recovery plan, IDS, password management system